

Capítulo 1

Introdução à Segurança da Informação

1.1. Objetivos

- Fornecer ao aluno uma visão geral sobre segurança da informação
- Entender a importância da segurança da informação no mundo de hoje
- Conhecer as principais ameaças
- Compreender a terminologia básica utilizada
- Conhecer algumas certificações da área

1.2. O que é segurança?

Segundo o dicionário da Wikipédia, **segurança** é um substantivo feminino, que significa:

- Condição ou estado de estar seguro ou protegido.
- Capacidade de manter seguro.
- Proteção contra a fuga ou escape.
- Profissional ou serviço responsável pela guarda e proteção de algo.
- Confiança em si mesmo.

Dentro do escopo com relação ao que iremos estudar, os três primeiros tópicos adequam-se perfeitamente ao que será abordado ao longo do curso. No entanto, veremos esses aspectos na visão do atacante, aquele que tem por objetivo justamente subverter a segurança.

E o que queremos proteger?

Vamos analisar o contexto atual em primeiro lugar..

Na época em que os nobres viviam em castelos e possuíam feudos, com mão de obra que trabalhavam por eles, entregando-lhes a maior parte de sua produção e ainda pagavam extorsivos importos, qual era o maior bem que possuíam? Terras! Isso mesmo, quem tinha maior número de terras era mais poderoso e possuía mais riqueza. Posto que quanto mais terras, maior a produção recebida das mãos dos camponeses que arrendavam as terras de seu suserano.

Após alguns séculos, com o surgimento da Revolução Industrial, esse panorama muda completamente... Os camponeses deixam os campos e passam a trabalhar nas fábricas, transformando-se em operários.

Quem nunca viu o filme “Tempos Modernos” de Chaplin? Chaplin ilustra muito bem como era a rotina desses operários.

Nessa fase da história da civilização, o maior ativo é a mão de obra,

juntamente com o capital. Quem tinha o maior número de operários, trabalhando “incansavelmente”, detinha o poder, pois possuía maior capital, gerado pela produção incessante das indústrias.

No entanto, como tudo o que é cíclico e está em constante mudança, o cenário mundial novamente se altera, inicialmente com o movimento iluminista.

O *Iluminismo*, a partir do século XVIII, permeando a Revolução Industrial, prepara o terreno para a mudança de paradigma que está por vir. Os grandes intelectuais desse movimento tinham como ideal a extensão dos princípios do conhecimento crítico a todos os campos do mundo humano. Supunham poder contribuir para o progresso da humanidade e para a superação dos resíduos de tirania e superstição que creditavam ao legado da Idade Média. A maior parte dos iluministas associava ainda o ideal de conhecimento crítico à tarefa do melhoramento do estado e da sociedade.

E com isso, começamos a ver, através de uma grande mudança de paradigma, que a detenção de informações ou conhecimentos, que tinham algum valor, é que define quem tem o poder nas mãos ou não. E surge, então, a **era da informação!**

Com esse acontecimento, inicia-se o surgimento da internet e a globalização, possibilitando o compartilhamento em massa da informação. Nesse momento não é mais a mão de obra, terras, máquinas ou capital que regem a economia e dita quem tem o poder, mas sim a informação, que se torna o principal ativo dessa era.

Estamos na **era da informação**, e nada mais lógico que um corpo de conhecimento fosse criado para dar a devida atenção às anomalias e proteger esse ativo tão importante. Essa área de atuação, que já existia há muito anos, mas agora com tarefas bem mais definidas, com regras e normas a serem seguidas é a **Segurança da Informação**, ou SI.

1.3. Segurança da Informação

A Segurança da Informação tem como principal objetivo, justamente, proteger as informações, que são os principais ativos atualmente, que sejam importantes para uma organização ou indivíduo.

Entendendo esse conceito, não é suficiente apenas conhecer as normas existentes e as várias formas possíveis de proteção, mas é necessário também conhecer os riscos inerentes e as possíveis formas de ataque.

De acordo com o maior estrategista que já existiu, Sun Tzu, se você conhece a si mesmo e ao seu inimigo, não precisará temer o resultado de mil batalhas. Afinal, se conhece os estratagemas empregados por atacantes maliciosos, estará muito mais capacitado para proteger seu principal ativo: a informação.

1.4. Padrões/Normas

1.4.1. ISO 27001

Essa norma aborda os padrões para sistemas de gestão de segurança da informação. Substitui a norma BS 7799-2

1.4.2. ISO 27002

Baseada na norma ISO 27001, essa norma trata das boas práticas de segurança da informação, onde indica uma série de possíveis controles dentro de cada contexto da área de segurança. A partir de 2006, tornou-se substituta da norma ISO 17799:2005.

1.4.3. Basileia II

É uma norma da área financeira, conhecida também como Acordo de Capital de Basileia II. Essa norma fixa-se em três pilares e 25 princípios básicos sobre contabilidade e supervisão bancária.

1.4.4. PCI-DSS

A norma Payment Card Industry Data Security Standard, é uma padronização internacional da área de segurança de informação definida pelo Payment Card Industry Security Standards Council. Essa norma foi criada para auxiliar as organizações que processam pagamentos por cartão de crédito na prevenção de fraudes, através de maior controle dos dados e sua exposição.

1.4.5. ITIL

É um conjunto de boas práticas para gestão, operação e manutenção de serviços de TI, aplicados na infraestrutura. A ITIL busca promover a gestão de TI com foco no cliente no serviço, apresentando um conjunto abrangente de processos e procedimentos gerenciais, organizados em disciplinas, com os quais uma organização pode fazer sua gestão tática e operacional em vista de alcançar o alinhamento estratégico com os negócios.

1.4.6. COBIT

Do inglês, ***Control Objectives for Information and related Technology***, é um guia de boas práticas, como um framework, voltadas para a gestão de TI. Inclui, em sua estrutura de práticas, um framework, controle de objetivos, mapas de auditoria, ferramentas para a sua implementação e um guia com técnicas de gerenciamento.

1.4.7. NIST 800 Series

Série de documentos, guias e pesquisas desenvolvidos pelo National Institute of Standards and Technology, voltadas para a área de segurança da informação. Essa série é composta de documentos considerados "Special Publications", os quais abordam desde segurança na tecnologia Bluetooth, até segurança em servidores.



Dica: o documento desta série que é equivalente ao que estamos estudando ao longo desse curso, que pode inclusive representar uma metodologia específica, é o NIST 800-115.

1.5. Por que precisamos de segurança?

- Evolução da tecnologia focando a facilidade de uso

Quanto mais a tecnologia evolui, mais fácil torna-se a operação dos novos sistemas e ferramentas. Já vai ao longe o tempo em que era necessário gravar de cabeça 500 comandos diferentes para utilizar o computador para as tarefas mais costumeiras e simples do dia a dia. Hoje em dia tudo está ao alcance de um clique do mouse, e quando não, de um movimento de cabeça, se pensarmos nos sistemas de captura de movimentos.

- Aumento do uso de redes e interligação das aplicações

Tudo está conectado atualmente! E quando uma máquina ou sistema é comprometido, tudo o que está ao seu redor corre o risco de ser comprometido também. Isso demanda uma maior capacidade de gerenciamento do parque computacional, que cresce exponencialmente e muitas vezes de forma desordenada.

- Diminuição do nível de conhecimento para a execução de um ataque avançado

Com a facilidade de uso aumentando gradativamente, a necessidade de conhecimento de alto nível para realizar ataques avançados também diminui. Se um adolescente de 12 anos procurar na internet sobre ataques de negação de serviço, por exemplo, encontrará ferramentas de simples utilização e pode facilmente derrubar um grande servidor.

- Aumento da complexidade para administração de infraestrutura de computadores e gerenciamento

Quanto maior o parque computacional, mais difícil se torna seu gerenciamento, e disso surgem inúmeros problemas graves, de consequências desastrosas. Com o aumento da complexidade da infraestrutura e, conseqüentemente, da sobrecarga dos administradores de rede, torna-se cada vez mais difícil gerenciar tudo o que ocorre e monitorar satisfatoriamente o funcionamento da infraestrutura organizacional.

1.6. Princípios básicos da segurança da informação

A área de SI possui três pilares básicos com o acréscimo de mais duas, que permitem a troca segura de informação, desde que nenhum deles seja violado. São eles:

1.6.1. Confidencialidade

Esse pilar é o responsável pelo controle de acesso à informação apenas por aquelas pessoas ou entidade que tenham permissão compatível com sua função e

determinada pelo dono daquela informação.

1.6.2. Integridade

Aqui, através dessa propriedade, é determinada a necessidade de garantir que a informação mantenha todas as suas características originais como determinadas pelo proprietário da informação.

1.6.3. Disponibilidade

Propriedade que define que determinada informação esteja sempre disponível para o acesso quando necessário, de maneira íntegra e fidedigna. Alguns dos ataques conhecidos buscam justamente derrubar a disponibilidade, e para algumas empresas o simples fato de não ter suas informações disponíveis durante determinado período de tempo, isso pode acarretar prejuízos estrondosos.

1.6.4. Autenticidade

Propriedade responsável por garantir que a informação vem da origem informada, permitindo a comunicação segura e garantia de que a informação a qual tem acesso é correta e de fonte confiável.

1.6.5. Legalidade

É a propriedade que define se determinada informação, ou operação, está de acordo com as leis vigentes no país. As mesmas leis que regem um país podem ser completamente diferentes em outro, o que pode ocasionar uma série de problemas, caso o sistema de gestão não seja adaptável.

Podemos ver na figura a seguir alguns dos distúrbios mais comuns aos pilares da SI, vinculados a ataques que visam à área de TI:

Abrangência	Ameaça	Exemplo
Confidencialidade	<i>Browsing</i>	Procurar por informações sem necessariamente saber seu tipo
	<i>Shoulder surfing</i> ("papagaio de pirata")	Olhar sobre o ombro da pessoa o que é digitado.
	Engenharia Social	Fingir ser alguém com a intenção de ter acesso a informações.
Integridade	Modificar uma mensagem	Interceptar uma mensagem, alterá-la e enviá-la ao seu destino original
	Alteração de logs de auditoria	Modificar os logs de auditoria, normalmente com a intenção de ocultar fatos
	Modificação de arquivos de configuração	Alterar arquivos críticos em um sistema para modificar sua funcionalidade.
Disponibilidade	Desastres naturais ou provocados	Vandalismo, incêndios, terremotos, terrorismo, vulcanismo, ...
	Negação de serviço (DoS)	Comprometimento de serviços de importância fundamental para processos
	Comprometimento de informações	Modificar dados de forma a ficarem inúteis para outras pessoas

O nível de segurança desejado, pode se consubstanciar em uma política de segurança que é seguida pela organização ou pessoa, para garantir que uma vez estabelecidos os princípios, aquele nível desejado seja perseguido e mantido.

É de extrema importância saber equilibrar o nível de segurança com a funcionalidade e facilidade de uso do sistema, pois o mais importante para a empresa é o negócio, e a segurança existe para proteger o negócio da empresa, e não atrapalhá-lo.

1.6.6. Terminologias de segurança

- Vulnerabilidade – fragilidade que pode fornecer uma porta de entrada a um atacante
- Ameaça – agente ou ação que se aproveita de uma vulnerabilidade
- Risco – (Impacto X Probabilidade) da ameaça ocorrer
- Ataque – Incidência da ameaça sobre a vulnerabilidade
- Exploit – Programa capaz de explorar uma vulnerabilidade

1.7. Ameaças e ataques

Em segurança da informação, precisamos estar atentos às possíveis ameaças que podem, de alguma maneira, comprometer os pilares de SI. A partir das ameaças, podemos ter noção dos riscos que envolvem a atividade organizacional. Para cada tipo de atividade, ou contexto, o conjunto de ameaças será diferente, requerendo também reações e posturas diferentes para diminuí-las.

Vamos separar as ameaças em dois grandes grupos: físicas e lógicas.

As ameaças físicas, caso ocorram, comprometerão o ambiente físico onde a informação está armazenada ou processada.

Dentre as ameaças físicas podemos considerar:

- Alagamento
- Raios
- Acessos indevidos
- Desabamentos

E no grupo das ameaças lógicas, podemos contar as seguintes:

- Infecção por vírus
- Acessos remotos à rede
- Violação de senhas

Assim como dividimos as ameaças em dois grandes grupos, os ataques também podem ser divididos da mesma maneira: Internos e Externos.

Os ataques internos representam por volta de 70% dos ataques que ocorrem aos sistemas e redes. Mesmo que a maioria das pessoas acreditem que a maior parte dos ataques surjam de fontes externas, essa é uma maneira errônea de encarar as coisas.

Dentre os ataques internos, encontramos em sua maioria, aqueles realizados por funcionários de dentro da própria organização, que estão insatisfeitos, buscam

vingança ou participam de alguma ação de espionagem industrial, vendendo as informações conseguidas para o concorrente.

Outro tipo de ataque vindo de “insiders”, surge de funcionários despreparados, que sem o devido conhecimento do funcionamento do sistema, ou das políticas organizacionais, age de maneira errônea, causando o comprometimento do sistema da empresa.

Quando vamos analisar os ataques externos, novamente nos deparamos com a possibilidade de comprometimentos cujos objetivos estejam vinculados à espionagem industrial, que apesar de ser ilegal, muitas organizações recorrem a esse expediente para não ficar para trás, na luta pelo domínio de mercado.

Outra possibilidade da origem de comprometimentos de sistemas, pode ser a curiosidade ou simplesmente o desafio que representa para um cracker, cujo objetivo de comprometer o sistema, seja basicamente isso: comprometer o sistema e poder dizer que foi ele quem fez isso. Ou então, o furto de dados que de alguma forma sejam úteis para o cracker. Bons exemplos desse tipo de ataques, podem ser encontrados no livro “A Arte de Invadir”, de autoria de Kevin Mitnick.

- Exemplo de ameaça:

“Uma chuva de granizo em alta velocidade”

- Exemplo de vulnerabilidade:

“Uma sala de equipamentos com janelas de vidro”

- Exemplo de ataque:

“A chuva de granizo contra as janelas de vidro”

O risco será calculado considerando a probabilidade de uma chuva de granizo em alta velocidade ocorrer e atingir a janela de vidro.

1.8. Mecanismos de segurança

Para mitigar ou diminuir sensivelmente as ameaças, podemos empregar uma série de dispositivos e mecanismos de segurança, sejam as ameaças físicas ou

lógicas. Para cada contexto, temos grupos diferentes de mecanismos que podem ser utilizados.

1.8.1. Mecanismos físicos

- Portas
- Trancas
- Paredes
- Blindagem
- Guardas
- Câmeras
- Sistemas de alarme
- Sistema de detecção de movimentos
- Biometria

Os mecanismos físicos de proteção, são barreiras que limitam o contacto ou acesso direto a informação ou a infra-estrutura (que garante a existência da informação) que a suporta.

1.8.2. Mecanismos lógicos

- Criptografia
- Firewall
- Anti-Vírus
- IDS
- IPS
- Proxy

- Anti-Spam

Os mecanismos lógicos, são barreiras que impedem ou limitam o acesso a informação, que está em ambiente controlado, geralmente eletrônico, e que, de outro modo, ficaria exposta a alteração não autorizada por elemento mal intencionado.

1.9. Serviços de segurança

Existe hoje em dia um elevado número de ferramentas e sistemas que pretendem fornecer segurança. Alguns exemplos são os detectores de intrusões, os antivírus, firewalls, firewalls locais, filtros anti-spam, fuzzers, analisadores de código, etc.

Além de dispositivos de segurança, também existem diversos serviços relacionados a segurança da informação.

Esses serviços precisam de profissionais com um conhecimento altamente especializado, primeiro por lidar com análises complexas, e segundo por envolver informações sigilosas que precisam de tratamento especial, para que não sejam comprometidas de alguma maneira.

Dentre os serviços oferecidos por profissionais de segurança estão:

- Criação de Políticas de Segurança
- Implantação de CSIRTs
- Hardening de Servidores
- Análise de Vulnerabilidade
- Teste de Invasão
- Análise de Aplicação
- Perícia Computacional
- Treinamento de Colaboradores
- Auditoria

1.10. Certificações

Na área de segurança, há muitas certificações reconhecidas pelo mercado. Sendo que cada uma delas possui um foco diferente, nível de conhecimento diferente e formas de avaliações diversas.

Abaixo listamos as principais certificações da área de SI:

- **CompTIA**

Security+

- **Cisco Systems**

CCNA Security • CCSP • CCIE Security

- **EC-Council**

CEH • CHFI • ECSA • ENSA • LPT

- **GIAC**

GSIF • GSEC • GCIA • GCFW • GCFA • GCIH • GPEN • GCUX • GCWN • GWAPT
• GAWN • GREM • GSE

- **ISACA**

CISA • CISM

- **(ISC)²**

CAP • CISSP • CSSLP • ISSAP • ISSEP • ISSMP • SSCP

- **ISECOM**

OPSA • OPST

- **Offensive Security**

OSCP • OSCE

- **Immunity**

NOP

Dentro do conteúdo estudado e de acordo com o contexto que estamos estudando, algumas certificações possuem em sua avaliação muito dos assuntos

abordados em aula. Podemos citar, dentre essas, as certificações:

- CEH, ECSA, LPT, OPSA, OSCP, GPEN

1.11. War Games

Para facilitar e possibilitar a utilização das técnicas aprendidas no curso, sem causar qualquer tipo de comprometimento a ambientes reais, podemos utilizar como ferramenta o que é conhecido como War Games: jogos que simulam ambientes reais e permitem colocar em prática técnicas de exploração de vulnerabilidades.

1.11.1. War Games desktop

- Uplink
- Hacker Evolution
- BSHacker
- Street Hacker
- MindLink
- Cyber Wars

1.11.2. War Games online

- <http://www.hackthissite.org/>
- <http://www.hackquest.de/>
- <http://www.hack4u.org/>

- <http://www.mod-x.co.uk/main.php>
- <http://bigchallenge.free.fr/>
- <http://www.hackertest.net/>